Studieprogramma SC-300 — Identity and Access Administrator

> 🌐 **Taal:** Nederlands | English

Duur: 7 weken · **Lab preset:** Standard (DC01 · MGMT01 · W11-01 · W11-02) **MS Learn pad:** Identity and Access Administrator **Examengewicht (bijgewerkt november 2025):**

Domein	Gewicht
Gebruikersidentiteiten implementeren en beheren	20–25%
Authenticatie en toegangsbeheer implementeren	25–30%
Workload-identiteiten plannen en implementeren	20–25%
Identity governance plannen en automatiseren	20–25%

> **Bijgewerkt:** Skills gemeten per 7 november 2025. Domeinen hernoemd en opnieuw gewogen. „Implement access management for Azure resources by using Azure roles" is **verwijderd** uit het examen. **Global Secure Access** is toegevoegd als nieuw onderdeel.

> **Voorwaarde:** Microsoft 365 E5 developer tenant + Azure subscription (MSDN) SC-300 heeft meer Azure-portal werkzaamheden dan MD-102/MS-102 **Tenantnotitie:** gebruik de lokale VM's voor hybride identiteit en de gedeelde dev-tenant voor Entra-, governance- en portalwerk. Zodra een oefening tenantbeleid of Entra-portalstappen noemt, hoort die in de tenant thuis.

> **Nieuw per november 2025:** *Implement Global Secure Access* is toegevoegd aan het examen (vervangt deels de Azure RBAC voor resources scope). SSW-Lab-scripts dekken dit onderdeel nog niet — raadpleeg de MS Learn module als zelfstandige voorbereiding.

Zo gebruik je dit studieprogramma

- Lees per week eerst de examendomeinen en leerdoelen; SC-300 draait sterk om keuzes maken tussen vergelijkbare identiteitsopties.
- Voer daarna de lab-oefeningen uit in Entra, Azure en waar nodig op de on-premises VM's zodat je hybride gedrag echt ziet gebeuren.
- Maak de kennischeck pas na theorie en lab, en let vooral op waarom een andere optie onjuist is.
- Werk je met tweetalige collega's, houd de Microsoft-termen bewust in beide talen bij, zoals *guest user / gastgebruiker* en *workload identity / workload-identiteit*.

Labdekking en verwachtingen

- **Sterke dekking in SSW-Lab:** hybride identiteit, Entra Connect, PHS/PTA, SSPR, Conditional Access, PIM, app-registraties, service principals en identity governance-basics.
- **Gedeeltelijke dekking:** lifecycle workflows, access reviews op grotere schaal, workload identities in complexe applicatieketens en sommige risicosignalen hangen af van tenantlicenties en testdata.
- **Nog apart bestuderen:** Global Secure Access, enkele nieuwste Entra-portalonderdelen en scenario's waarvoor een tweede tenant of productieachtige partnertrust nodig is.
- Gebruik de labstappen om begrip op te bouwen, maar toets jezelf bij elk onderwerp ook op ontwerpkeuzes: wanneer kies je welke identiteit, policy of governance-aanpak?

Werkwijze voor kennischecks

- Beantwoord eerst welk ontwerp je zou kiezen en daarna pas hoe je het technisch uitvoert.
- Benoem bij elke vraag expliciet welk risico wordt verkleind of welk governanceprobleem wordt opgelost.
- Herhaal fout beantwoorde vragen met focus op terminologie: in SC-300 lijken veel opties op elkaar, maar de randvoorwaarden verschillen.
- Besteed extra aandacht aan guest access, Conditional Access, workload identities en governance, omdat daar veel scenario-vragen uit ontstaan.

Week 1 — Entra ID fundamenten en hybride identiteit

> **Examendomein:** Gebruikersidentiteiten implementeren en beheren · **Gewicht:** 20–25%

> **Praktijkscenario:** Een middelgroot productiebedrijf met 800 on-premises Active Directory-gebruikers migreert naar Microsoft 365. Volgens het securitybeleid mogen wachtwoordhashes niet in de cloud worden opgeslagen. Tegelijk moet SSPR beschikbaar zijn zodat medewerkers hun wachtwoord vanaf het inlogscherm kunnen resetten zonder tussenkomst van de helpdesk. Jij moet de juiste hybride authenticatiemethode kiezen en het selfservice-herstelproces betrouwbaar inrichten.

Leerdoelen

- [ ] De drie hybride authenticatiemethoden (PHS, PTA, ADFS) benoemen en het juiste scenario voor elk kiezen
- [ ] Entra Connect Sync installeren en Password Hash Synchronization configureren
- [ ] Een handmatige sync-cyclus starten met `Start-ADSyncSyncCycle` en de resultaten interpreteren
- [ ] Seamless SSO uitleggen en de rol van het AZUREADSSOACC-computeraccount beschrijven
- [ ] Password Writeback inschakelen en de relatie met SSPR verklaren
- [ ] Entra ID Audit logs filteren op relevante events zoals gebruikers-aanmaak en rolwijzigingen

MS Learn modules

- Implement initial configuration of Microsoft Entra ID
- Create, configure, and manage identities
- Implement and manage hybrid identity

Kernbegrippen

Begrip	Uitleg
Entra Connect Sync	On-premises synchronisatieagent die Active Directory-objecten synchroniseert naar Entra ID
Password Hash Sync (PHS)	Gesynchroniseerde wachtwoordhashes in Entra ID — authenticatie vindt in de cloud plaats; werkt ook als on-prem AD offline is
Pass-through Authentication (PTA)	Authenticatie wordt via een lokale agent doorgestuurd naar on-prem AD; wachtwoordhash wordt nooit opgeslagen in de cloud
Seamless SSO	Automatische inlog voor domain-joined apparaten via Kerberos zonder wachtwoordinvoer; vereist het computeraccount AZUREADSSOACC in AD
Password Writeback	Wachtwoordwijzigingen in de cloud worden teruggeschreven naar on-prem AD; vereist voor SSPR in hybride omgevingen
Staging mode	Entra Connect staat in passieve modus — berekent sync-wijzigingen maar past ze niet toe; handig voor failover-configuratie
Soft delete	Verwijderde gebruiker blijft 30 dagen herstelbaar in de prullenbak van Entra ID
Hard delete	Permanente verwijdering; account is niet meer te herstellen
Delta sync	Synchronisatiecyclus die alleen gewijzigde objecten verwerkt (snel); tegenoverstelling van Initial (full) sync
Entra Connect Health	Monitoringservice die de gezondheid en prestaties van de synchronisatieinfrastructuur bewaakt

Lab oefeningen (SSW-Lab)

VM	Taak
LAB-DC01	Verifieer AD-structuur: `Get-ADForest`, `Get-ADDomain`, `Get-ADUser -Filter *`
LAB-DC01	Installeer Azure AD Connect Sync → configureer *Password Hash Sync*
LAB-DC01	Controleer sync: `Start-ADSyncSyncCycle -PolicyType Delta`
LAB-MGMT01	Open **Entra admin center** (entra.microsoft.com) → verifieer sync-status
LAB-MGMT01	Configureer *Custom Security Attributes* voor gebruikersclassificatie

VM	Taak
LAB-MGMT01	Bekijk *Audit logs* in Entra ID → filter op gebruikers-aanmaak events

Labcommando's

```
# Start een delta-synccyclus vanaf de AD Connect-server
Start-ADSyncSyncCycle -PolicyType Delta

# Bekijk de status van de syncconnector
Get-ADSyncConnector | Select-Object Name, ConnectorTypeName, LastSyncTime

# Herstel een soft-deleted gebruiker via Microsoft Graph PowerShell
Restore-MgDirectoryDeletedItem -DirectoryObjectId "<object-id>"

# Forceer een volledige synccyclus (spaarzaam gebruiken)
Start-ADSyncSyncCycle -PolicyType Initial
```

Kennischeck

1. Wat zijn de drie authenticatiemethoden bij hybride identiteit en wanneer gebruik je welke?
2. Hoe werkt *Seamless SSO* en welke Kerberos-component is betrokken?
3. Wat is het verschil tussen *soft delete* en *hard delete* van een Entra ID-gebruiker?
4. Hoe configureer je *password writeback* en waarom is het nodig voor SSPR?

▶ Antwoorden

Scenario-vragen:

5. Een bedrijf gebruikt Pass-through Authentication (PTA) voor 1.200 gebruikers. Tijdens een gepland onderhoudsvenster worden de on-premises PTA-agentservers vier uur offline gehaald. Wat gebeurt er met gebruikers die tijdens dit venster proberen in te loggen op Microsoft 365?
   - A. Gebruikers kunnen nog steeds inloggen omdat Entra ID inloggegevens 24 uur lang in de cache bewaart
   - B. Gebruikers kunnen niet inloggen omdat PTA de agent nodig heeft om inloggegevens te valideren
   - C. Gebruikers worden automatisch doorgestuurd naar SSPR om hun wachtwoord te resetten
   - D. Gebruikers kunnen inloggen met de laatste bekende wachtwoordhash die in Entra ID is opgeslagen

▶ Antwoord

6. Een medewerker heeft het bedrijf 15 dagen geleden verlaten en het account is verwijderd in Entra ID. De HR-afdeling meldt dat de medewerker terugkeert en wil het account volledig herstellen, inclusief alle groepslidmaatschappen en licentietoewijzingen. Welke actie moet de Identity Administrator uitvoeren?
   - A. Handmatig een nieuw account aanmaken en groepslidmaatschappen opnieuw toevoegen
   - B. De soft-deleted gebruiker herstellen via de Entra-portal of `Restore-MgDirectoryDeletedItem`
   - C. Entra Connect Sync gebruiken om het account opnieuw te synchroniseren vanuit on-premises AD
   - D. Contact opnemen met Microsoft Support om het hard-deleted account te herstellen

▶ Antwoord

7. Een bedrijf wil Entra Cloud Sync gebruiken in plaats van Entra Connect Sync. In welk scenario is Entra Cloud Sync de betere keuze?
   - A. Het bedrijf vereist attribute writeback voor apparaten naar on-premises AD
   - B. Het bedrijf heeft drie afzonderlijke AD-forests en heeft een eenvoudige sync-configuratie nodig zonder writeback-vereisten
   - C. Het bedrijf moet Exchange Hybrid-attributen synchroniseren inclusief mailboxinstellingen
   - D. Het bedrijf gebruikt AD FS en wil migreren naar PTA

▶ Antwoord

Week 2 — Externe identiteiten en Entra B2B

> **Examendomein:** Gebruikersidentiteiten implementeren en beheren · **Gewicht:** 20–25%

> **Praktijkscenario:** Een Sogeti-consultant helpt een financiële klant drie strategische partners toegang te geven tot een gedeelde SharePoint-site en Teams-werkruimte. De securityafdeling eist dat partnergebruikers hun eigen bedrijfsidentiteit gebruiken, dat MFA-claims van een vertrouwde partner-tenant worden geaccepteerd zonder dubbele prompts, en dat accounts met hoog risico direct worden geblokkeerd. Jij ontwerpt B2B-toegang, cross-tenant trust en Identity Protection-beleid dat dit afdwingt.

Leerdoelen

- ☐ Het verschil tussen B2B Collaboration en B2B Direct Connect uitleggen en het juiste scenario kiezen
- ☐ Cross-tenant access settings configureren: inbound en outbound vertrouwen instellen per partner-tenant
- ☐ Entra ID Protection inschakelen en de risicodetectie-dashboard interpreteren

- ☐ Een User risk policy en Sign-in risk policy aanmaken en testen
- ☐ Risky users en risky sign-ins handmatig remediëren (dismiss, confirm compromise, wachtwoordreset)
- ☐ Identity Protection-signalen verbinden aan het bredere Zero Trust-framework

MS Learn modules

- Implement and manage external identities
- Implement and manage Microsoft Entra ID Protection

Kernbegrippen

Begrip	Uitleg
B2B Collaboration	Externe gebruikers uitnodigen als gastgebruikers; zij krijgen een guest-object in jouw tenant en authenticeren bij hun eigen tenant of via OTP
B2B Direct Connect	Directe vertrouwensrelatie tussen twee tenants zonder guest-objecten; de externe gebruiker verschijnt niet in jouw directory (momenteel primair voor Teams shared channels)
Cross-tenant access settings	Beleid waarmee je per externe tenant instelt wat je inbound (wat externen bij jou mogen) en outbound (wat jouw gebruikers bij externen mogen) toestaat
Inbound trust	Vertrouwen van MFA-claims of compliant-device-claims van een partner-tenant — voorkomt dubbele MFA-challenges
One-time passcode (OTP)	Fallback-authenticatie via e-mailcode voor gasten zonder Azure AD-, Microsoft- of Google-account
Sign-in risk	Per inlogpoging berekende kans dat die poging niet door de legitieme gebruiker is gedaan (bijv. anoniem IP, onmogelijk reizen)
User risk	Cumulatieve inschatting dat een account gecompromitteerd is (bijv. gelekte credentials op het dark web)
Atypical travel	Risicodetectie: inlogpogingen vanuit twee geografisch ver uiteen gelegen locaties in een onmogelijk korte tijd
Dismiss risk	Beheerder markeert een risico als vals-positief; risicoscore wordt gecleard
Confirm compromise	Beheerder bevestigt dat het account echt gecompromitteerd is; triggert verdere acties zoals accountblokkering

Lab oefeningen (SSW-Lab)

VM	Taak
LAB-MGMT01	Nodig een externe B2B-gebruiker uit (gebruik een persoonlijk of second tenant-account)
LAB-MGMT01	Configureer *Cross-tenant access settings*: blokkeer inbound access voor specifieke tenants

VM	Taak
LAB-MGMT01	Schakel *Entra ID Protection* in → bekijk *Risk detections* dashboard
LAB-MGMT01	Configureer *User risk policy*: hoog risico → wachtwoordwijziging verplicht
LAB-MGMT01	Configureer *Sign-in risk policy*: medium risico → MFA verplicht
LAB-W11-01	Simuleer risky sign-in: log in met TestUser01 vanuit anonieme browser-sessie

Labcommando's

```
# Nodig een B2B-gastgebruiker uit via Microsoft Graph PowerShell
New-MgInvitation -InvitedUserEmailAddress "partner@contoso.com" `
    -InviteRedirectUrl "https://myapps.microsoft.com" `
    -SendInvitationMessage:$true

# Toon alle gastgebruikers in de tenant
Get-MgUser -Filter "userType eq 'Guest'" | Select-Object DisplayName, Mail,
UserPrincipalName

# Verwerp een user risk (markeer als false positive)
Invoke-MgDismissRiskyUser -UserIds "<user-object-id>"

# Bevestig accountcompromittering (start aanvullende beschermingsacties)
Invoke-MgConfirmRiskyUserCompromised -UserIds "<user-object-id>"
```

Kennischeck

1. Wat is het verschil tussen *B2B direct connect* en *B2B collaboration*?
2. Hoe werkt *Identity Protection* — welke signalen gebruikt het voor risicoscores?
3. Wat is een *risky user* versus een *risky sign-in*? Hoe remedieer je elk?
4. Wat doet een *Conditional Access policy op basis van user risk*?

▶ Antwoorden

Scenario-vragen:

5. Een bedrijf gebruikt B2B collaboration om partnerconsultants toegang te geven tot een SharePoint-site. Het securityteam merkt dat partnergebruikers twee keer om MFA worden gevraagd — eenmaal bij het inloggen in hun eigen tenant en nogmaals bij het benaderen van de bedrijfsresources. Welke configuratie elimineert de dubbele MFA-prompt zonder de beveiliging te verlagen?
   - A. MFA-vereisten uitschakelen voor alle gastgebruikers in de Conditional Access policy
   - B. Inbound cross-tenant access settings configureren om MFA-claims van de partner-tenant te vertrouwen
   - C. B2B Direct Connect inschakelen in plaats van B2B collaboration voor de partner-tenant

- D. Gastgebruikers voor elke sessie een Temporary Access Pass toewijzen

▶ Antwoord

6. Het account van een gebruiker toont een hoog user risk in Identity Protection door gelekte credentials op het dark web. Het bedrijf heeft een Conditional Access policy die gebruikers met hoog risico blokkeert. De gebruiker belt de helpdesk omdat hij niet kan inloggen. Welke remediation-stap geeft de gebruiker toegang terug zonder dat een beheerder het risico handmatig hoeft te resetten?
   - A. De gebruiker vragen 24 uur te wachten totdat het risico automatisch verloopt
   - B. De beheerder verwerpt het risico in de Identity Protection-portal
   - C. De gebruiker tijdelijk uitsluiten van alle Conditional Access policies
   - D. De gebruiker voert een self-service wachtwoordreset uit via SSPR, waardoor het user risk na voltooiing wordt gewist

▶ Antwoord

7. Een bedrijf wil gebruikers van Tenant A toegang geven tot Teams shared channels in Tenant B zonder gastobjecten aan te maken in de directory van Tenant B. Welke functie moet de beheerder configureren?
   - A. B2B collaboration met automatische uitnodigingsacceptatie
   - B. Cross-tenant synchronisatie van Tenant A naar Tenant B
   - C. B2B Direct Connect met een wederzijdse vertrouwensconfiguratie tussen de twee tenants
   - D. Entra Application Proxy met een connector in Tenant B

▶ Antwoord

Week 3 — Authenticatiemethoden en MFA

> **Examendomein:** Authenticatie en toegangsbeheer implementeren · **Gewicht:** 25–30%

> **Praktijkscenario:** Een overheidsorganisatie wil phishing-resistente MFA voor 2.500 medewerkers als onderdeel van een Zero Trust-programma. De helpdesk verwerkt wekelijks tientallen wachtwoordresetverzoeken. Jij moet een strategie ontwerpen waarin FIDO2-sleutels voor bevoorrechte gebruikers, Microsoft Authenticator met passkeys voor reguliere medewerkers en Temporary Access Pass voor onboarding en herstel logisch samenkomen in een modern beleid.

Leerdoelen

- ☐ Het Authentication methods-beleid configureren en de migratie van legacy per-user MFA uitleggen
- ☐ FIDO2, Microsoft Authenticator passwordless en passkeys vergelijken op beveiligingsniveau
- ☐ Een Temporary Access Pass (TAP) aanmaken en de juiste gebruiksscenario's benoemen

- ☐ Windows Hello for Business in een hybride omgeving implementeren en de vereisten beschrijven
- ☐ Authentication Strength beleidsregels aanmaken en koppelen aan een Conditional Access policy
- ☐ Phishing-resistant MFA-methoden identificeren en onderscheiden van niet-phishing-resistente methoden

MS Learn modules

- Plan and implement multifactor authentication
- Implement passwordless authentication
- Manage user authentication

Kernbegrippen

Begrip	Uitleg
FIDO2	Passwordless hardwaresleutel (bijv. YubiKey, Feitian) — phishing-resistent omdat de sleutel gebonden is aan een specifiek domein; sterkste beschikbare methode
Microsoft Authenticator passwordless	Aanmelding via push-notificatie met number matching op de telefoon; geen wachtwoord vereist; phishing-resistent via number matching
Passkey	FIDO2-gebaseerde inlogmethode opgeslagen in de Microsoft Authenticator app — combineert gemak van app met FIDO2-sterkte
Temporary Access Pass (TAP)	Tijdelijke toegangscode (eenmalig of meerdere keren) voor onboarding, herstel na verlies van MFA-methode, of tijdelijke toegang
Authentication Strength	Beleid dat specifieke authenticatiecombinaties vereist (bijv. phishing-resistant MFA); wordt als Grant control gebruikt in Conditional Access
Legacy per-user MFA	Verouderd MFA-systeem per gebruiker via de MFA-portal (account.activedirectory.windowsazure.com); moet worden gemigreerd naar Authentication methods policy
SSPR	Self-Service Password Reset — gebruikers resetten hun eigen wachtwoord via aka.ms/sspr zonder IT-tussenkomst
Combined registration	Gecombineerde registratie van MFA-methoden en SSPR in één workflow via aka.ms/mysecurityinfo
Certificate-based authentication (CBA)	Authenticatie met een X.509-certificaat als primaire methode; phishing-resistent; vereist PKI-infrastructuur
Password Protection	Blokkeert zwakke en organisatiespecifieke wachtwoorden via een global en custom banned password list

Lab oefeningen (SSW-Lab)

VM	Taak
LAB-MGMT01	Open **Entra** → **Security** → **Authentication methods** → activeer FIDO2 en Authenticator
LAB-W11-01	Registreer *Microsoft Authenticator* als MFA-methode voor TestUser01
LAB-W11-01	Registreer *Windows Hello for Business* op W11-01
LAB-MGMT01	Configureer *Authentication strength* in Conditional Access: Phishing-resistant MFA
LAB-MGMT01	Bekijk *Authentication methods activity* report → analyseer methode-gebruik
LAB-MGMT01	Schakel *legacy per-user MFA* uit → migreer naar Conditional Access-based MFA

Labcommando's

```
# Maak een Temporary Access Pass aan voor een gebruiker
New-MgUserAuthenticationTemporaryAccessPassMethod -UserId "<user-id>" `
    -LifetimeInMinutes 60 -IsUsableOnce:$true

# Toon geregistreerde authenticatiemethoden voor een gebruiker
Get-MgUserAuthenticationMethod -UserId "<user-id>"

# Verwijder een specifieke authenticatiemethode (bijv. een verloren FIDO2-
sleutel)
Remove-MgUserAuthenticationFido2Method -UserId "<user-id>" `
    -Fido2AuthenticationMethodId "<method-id>"

# Rapporteer over registraties van authenticatiemethoden in de tenant
Get-MgReportAuthenticationMethodUserRegistrationDetail |
    Select-Object UserPrincipalName, IsMfaRegistered, IsPasswordlessCapable
```

Kennischeck

1. Wat is *phishing-resistant MFA* en welke methoden vallen hieronder?
2. Hoe werkt *Windows Hello for Business* in hybride omgeving?
3. Wat is het verschil tussen *Authentication methods policy* en *legacy MFA-instellingen*?
4. Wanneer gebruik je *Temporary Access Pass (TAP)*?

▶ Antwoorden

Scenario-vragen:

5. Het securityteam van een bedrijf wil ervoor zorgen dat gebruikers die inloggen op een gevoelige financiële applicatie uitsluitend phishing-resistente MFA gebruiken. Gewone MFA (SMS of standaard Authenticator-push) mag de vereiste niet vervullen. Welke Conditional Access-configuratie bereikt dit?
   - A. Een CA policy aanmaken gericht op de financiële app met grant control "Require multi-factor authentication"
   - B. Een CA policy aanmaken gericht op de financiële app met een aangepaste Authentication strength die alleen FIDO2 en certificate-based authentication bevat
   - C. Een Entra ID Protection sign-in risk policy inschakelen op High voor de financiële app
   - D. De Enterprise Application van de financiële app configureren om apparaatcompliance te vereisen

▶ Antwoord

6. Een nieuwe medewerker treedt in dienst bij een bedrijf dat passwordless authenticatie gebruikt. De medewerker heeft nog geen authenticatiemethoden geregistreerd. De IT-beheerder moet de medewerker op de eerste werkdag laten inloggen en een FIDO2-sleutel laten registreren. Welke inlogmogelijkheid moet de beheerder aanmaken voor de medewerker?
   - A. Een Temporary Access Pass (TAP) met `isUsableOnce: false` zodat de medewerker meerdere keren kan inloggen tijdens het registratieproces
   - B. Een standaard tijdelijk wachtwoord dat na 24 uur verloopt
   - C. Een via SSPR gegenereerde e-mailverificatiecode
   - D. Een gastaccount in een aparte onboarding-tenant

▶ Antwoord

7. Een organisatie migreert van legacy per-user MFA naar Conditional Access-beheerde MFA. Tijdens het testen melden sommige gebruikers dat ze nog steeds om MFA worden gevraagd, ook al staat de nieuwe CA policy in report-only modus. Wat veroorzaakt de extra MFA-prompts hoogstwaarschijnlijk?
   - A. De CA policy in report-only modus dwingt MFA nog steeds af naast het loggen
   - B. De gebruikers hebben nog steeds per-user MFA ingeschakeld in de legacy MFA-portal, die onafhankelijk van Conditional Access werkt
   - C. De gecombineerde registratieportal triggert MFA-registratieprompts
   - D. De gebruikers hebben nog geen methode geregistreerd in de Authentication methods policy

▶ Antwoord

Week 4 — Conditional Access en Global Secure Access

> **Examendomein:** Authenticatie en toegangsbeheer implementeren · **Gewicht:** 25–30%

> **Praktijkscenario:** Een advocatenkantoor met 350 gebruikers en veel thuiswerkers wil afdwingen dat alleen beheerde of compliant apparaten bij SharePoint en Teams kunnen, dat toegang van buiten de EU step-up authenticatie vereist en dat het uitschakelen van een Conditional Access-policy altijd een extra goedkeuring nodig heeft. Tegelijk onderzoekt men de overstap van klassieke VPN naar zero-trust toegang per applicatie. Jij vertaalt deze eisen naar Conditional Access, protected actions en Global Secure Access-keuzes.

Leerdoelen

- ☐ Een Conditional Access-policy aanmaken met signals, conditions en grant/session controls
- ☐ De What If-tool gebruiken om CA-beleid te simuleren en te troubleshooten
- ☐ Named Locations en compliant network definiëren en gebruiken in CA-policies
- ☐ Authentication contexts en Protected Actions configureren voor step-up authenticatie
- ☐ Continuous Access Evaluation (CAE) uitleggen en onderscheiden van standaard tokenlevensduur
- ☐ Global Secure Access uitleggen: de drie verkeersprofielen (Private Access, Internet Access, M365 Access) beschrijven
- ☐ Het verschil tussen Private Access en traditionele VPN verklaren in termen van Zero Trust

MS Learn modules

- Plan, implement, and administer Conditional Access
- Implement Conditional Access for cloud app access
- Implement Global Secure Access

Kernbegrippen

Begrip	Uitleg
CA Signals	De invoerparameters voor de CA-beleidsengine: gebruiker/groep/rol, applicatie, locatie, apparaatcompliance, sign-in risico, user risico
Grant control	CA-uitkomst die toegang verleent of weigert, eventueel met voorwaarden: MFA vereisen, compliant device, hybride join, of Block
Session control	CA-uitkomst die een bestaande sessie beperkt: sign-in frequency, persistent browser session, app-enforced restrictions, CASB-integratie
Named Location	IP-ranges of landen gemarkeerd als vertrouwd of te blokkeren; gebruikt als CA-signal voor locatiegebaseerde beslissingen
Compliant network	Verkeerslocatie die via Global Secure Access verloopt en daarmee als vertrouwd netwerk wordt beschouwd in CA
Continuous Access Evaluation (CAE)	Real-time intrekking van tokens binnen seconden bij risicogebeurtenissen (bijv. wachtwoordwijziging, locatieverandering, account uitgeschakeld) in plaats van wachten op tokenexpiry

Begrip	Uitleg
Authentication context	Een tag die aan een CA-policy wordt gekoppeld en vervolgens door een app wordt aangevraagd bij een risicovolle actie (step-up authenticatie)
Protected Actions	Hoog-privilege Entra-operaties (bijv. CA-policy uitschakelen, PIM-instellingen wijzigen) die altijd extra CA-verificatie vereisen
Global Secure Access (GSA)	Microsoft's Security Service Edge-platform — combineert Zero Trust Network Access (ZTNA) en Secure Web Gateway (SWG)
Private Access	GSA-component die zero trust-toegang biedt tot on-premises en private apps zonder traditionele VPN; toegang is per-app in plaats van per-netwerk
Internet Access for M365	Geoptimaliseerde GSA-tunnel specifiek voor Microsoft 365-verkeer met beleidshandhaving en verkeerslogboeken

Lab oefeningen (SSW-Lab)

VM	Taak
LAB-MGMT01	Maak CA-policy: blokkeer toegang tot alle apps van buiten compliance-devices
LAB-MGMT01	Maak CA-policy: MFA verplicht voor beheerderrollen bij elke sign-in
LAB-MGMT01	Gebruik *What If* tool in CA om access-beslissingen te simuleren
LAB-W11-01	Test CA-policy als TestUser01 → verifieer welke controls worden afgedwongen
LAB-W11-02	Test met niet-enrolled device → verifieer blokkering
LAB-MGMT01	Schakel *Sign-in frequency* in voor gevoelige applicaties (elke 4 uur re-auth)
LAB-MGMT01	Bekijk **CA insights and reporting** workbook in Entra ID
LAB-MGMT01	Open **Global Secure Access** in het Entra admin center → verken Private Access en Internet Access-instellingen
LAB-MGMT01	Schakel *Internet Access voor Microsoft 365* in via Global Secure Access → bekijk verkeerslogboeken

Labcommando's

```
# Toon alle Conditional Access-policies en hun status
Get-MgIdentityConditionalAccessPolicy |
    Select-Object DisplayName, State, CreatedDateTime

# Haal sign-in-logs op gefilterd op CA-policyfouten (vereist Log Analytics of MS
Graph)
# Via Microsoft Graph PowerShell:
Get-MgAuditLogSignIn -Filter "conditionalAccessStatus eq 'failure'" -Top 20 |
    Select-Object UserPrincipalName, AppDisplayName, ConditionalAccessStatus

# Toon alle named locations
Get-MgIdentityConditionalAccessNamedLocation | Select-Object DisplayName, Id

# Schakel een CA-policystatus in of werk deze bij
(enabled/disabled/enabledForReportingButNotEnforced)
Update-MgIdentityConditionalAccessPolicy -ConditionalAccessPolicyId "<policy-id>"
`
    -State "enabledForReportingButNotEnforced"
```

Kennischeck

1. Wat is het verschil tussen *Block* en *Grant with MFA* in Conditional Access?
2. Hoe werkt *Named Locations* en wanneer gebruik je *compliant network*?
3. Wat zijn *Authentication contexts* en wanneer gebruik je ze?
4. Hoe voorkom je *lock-out* bij CA-migratie in productie?
5. Wat is *Global Secure Access* en wat zijn de drie verkeersprofielen (Private, Internet, M365)?
6. Wat is het verschil tussen *Private Access* en een traditionele VPN?

▶ Antwoorden

Scenario-vragen:

7. Een beheerder schakelt een nieuwe Conditional Access policy in afdwingingsmodus in die apparaatcompliance vereist voor alle cloud-apps. De volgende ochtend kan de IT-beheerder niet inloggen bij de Entra-portal vanaf zijn persoonlijke laptop om de policy te herstellen. Wat had de beheerder van tevoren moeten configureren om van deze situatie te herstellen?
    - A. Een Named Location voor het thuis-IP-adres van de beheerder, uitgesloten van de policy
    - B. Een break-glass account dat is uitgesloten van alle Conditional Access policies
    - C. De What If-tool om de policy te pre-testen voordat deze werd ingeschakeld
    - D. Een Conditional Access policy in report-only modus die parallel wordt uitgevoerd

▶ Antwoord

8. Een CA policy maakt gebruik van Continuous Access Evaluation (CAE). Een beheerder trekt om 14:00 alle actieve sessies in voor een gebruikersaccount omdat het account verdacht is gecompromitteerd. De gebruiker heeft een actief toegangstoken dat om 13:30 is uitgegeven. Wat gebeurt er met de sessie van de gebruiker?
    - A. De sessie van de gebruiker gaat door totdat het toegangstoken verloopt rond 15:00–15:30
    - B. De sessie van de gebruiker wordt binnen seconden beëindigd omdat CAE near-real-time tokenintrekking mogelijk maakt
    - C. De sessie van de gebruiker wordt pas beëindigd nadat de gebruiker opnieuw inlogt
    - D. De gebruiker ontvangt binnen het volgende uur een MFA-prompt om opnieuw te verifiëren

▶ Antwoord

9. Een Global Secure Access-beheerder wil ervoor zorgen dat gebruikers die toegang hebben tot een gevoelige on-premises HR-applicatie verbonden zijn via de GSA-client — niet vanuit willekeurige internetlocaties. Welke CA-voorwaarde moet worden geconfigureerd?
    - A. Named Location beperkt tot de kantoor-IP-ranges van het bedrijf
    - B. Apparaatcompliance vereist
    - C. Compliant network locatie (Global Secure Access)
    - D. Sign-in risico lager dan Medium

▶ Antwoord

Week 5 — Applicatietoegang en app registraties

> **Examendomein:** Workload-identiteiten plannen en implementeren · **Gewicht:** 20–25%

> **Praktijkscenario:** Een Sogeti DevOps-team bouwt voor een bank een intern automatiseringsplatform dat via een Azure Function e-mail uit een shared mailbox leest, resultaten naar SharePoint schrijft en een interne REST-API aanroept. De securityafdeling staat geen wachtwoorden of client secrets toe: alleen managed identities en app-only toestemming met expliciete admin consent zijn toegestaan. Daarnaast moeten bestaande derdepartij-apps met te brede rechten worden opgeschoond. Jij moet workload identities, API-permissies en governance rond enterprise apps correct inrichten.

Leerdoelen

- ☐ Het verschil tussen een App Registration en een Enterprise Application uitleggen en de relatie beschrijven
- ☐ Delegated en Application API permissions configureren en het effect van admin consent benoemen
- ☐ De OAuth 2.0 authorization code flow beschrijven in de context van Entra ID

- ☐ Een Managed Identity (system-assigned en user-assigned) aanmaken en het gebruik ervan uitleggen
- ☐ Entra Application Proxy configureren voor het publiceren van on-premises webapplicaties
- ☐ SCIM-provisioning instellen voor automatisch gebruikersbeheer in een SaaS-applicatie

MS Learn modules

- Manage and implement application access in Azure AD
- Implement app registrations
- Integrate single sign-on in Microsoft Entra ID

Kernbegrippen

Begrip	Uitleg
App Registration	Technische registratie van een applicatie bij Entra ID voor OAuth/OIDC; geconfigureerd door de app-ontwikkelaar (redirect URIs, secrets, scopes)
Enterprise Application	Serviceprincipal-instantie van een app in jouw tenant; hier beheer je wie toegang heeft, SSO-instellingen en SCIM-provisioning
Service Principal	Identiteitsrepresentatie van een applicatie of dienst in Entra ID; elke app registration levert automatisch een service principal op in de tenant
Managed Identity	Azure-resource-identiteit zonder beheerdersreferenties; het Azure-platform beheert de tokenuitgifte automatisch — geen wachtwoorden die kunnen lekken
System-assigned Managed Identity	Identiteit gekoppeld aan één specifieke Azure-resource; lifecycle is gelijk aan die resource (verwijderd als resource verwijderd wordt)
User-assigned Managed Identity	Zelfstandige identiteit die aan meerdere Azure-resources kan worden toegewezen; onafhankelijke lifecycle
Delegated permission	API-recht waarbij de app handelt namens een aangemelde gebruiker; de gebruiker zelf moet toestemming geven (of admin namens iedereen)
Application permission	API-recht waarbij de app als zichzelf handelt zonder gebruikerscontext (daemon/service); vereist altijd admin consent
Entra Application Proxy	Publiceert on-premises webapplicaties veilig via Entra ID zonder inkomende firewallpoorten; connector maakt uitgaande verbinding naar Azure
SCIM	System for Cross-domain Identity Management — open standaard voor het automatisch aanmaken, bijwerken en verwijderen van gebruikers in SaaS-applicaties

Lab oefeningen (SSW-Lab)

VM	Taak
LAB-MGMT01	Registreer een test-app in **Entra** → **App registrations**

VM	Taak
LAB-MGMT01	Voeg *API permissions* toe: `User.Read` en `Mail.Read` → admin consent verlenen
LAB-MGMT01	Maak een *client secret* aan → noteer de waarde
LAB-MGMT01	Configureer SSO voor een gallery-app (bijv. GitHub) via *Enterprise applications*
LAB-MGMT01	Configureer *App proxy* voor een on-premises app (gebruik MGMT01 als testserver)
LAB-MGMT01	Wijs de app toe aan een groep → bekijk toegang in *My Apps* portal

Labcommando's

```
# Toon alle app registrations in de tenant
Get-MgApplication | Select-Object DisplayName, AppId, CreatedDateTime

# Toon API-permissies voor een specifieke app registration
Get-MgApplicationRequiredResourceAccess -ApplicationId "<app-object-id>"

# Maak een nieuw client secret aan voor een app registration
Add-MgApplicationPassword -ApplicationId "<app-object-id>" `
    -PasswordCredential @{ DisplayName = "LabSecret"; EndDateTime = "2026-01-01"
}

# Toon alle enterprise applications (service principals) met app-permissies
Get-MgServicePrincipal -Filter "servicePrincipalType eq 'Application'" |
    Select-Object DisplayName, AppId, AppRoles
```

Kennischeck

1. Wat is het verschil tussen een *App registration* en een *Enterprise application*?
2. Hoe werkt OAuth 2.0 *authorization code flow* in het kort?
3. Wat is een *managed identity* en wanneer gebruik je system-assigned versus user-assigned?
4. Wat doet *application proxy* en welke ports heeft het nodig?

▶ Antwoorden

Scenario-vragen:

5. Een ontwikkelaar registreert een Azure Function-app in Entra ID om via Microsoft Graph de agenda's van alle gebruikers te lezen (`Calendars.Read`). De functie wordt uitgevoerd als achtergrondservice zonder aangemelde gebruiker. Welk type permissie is vereist en welke aanvullende stap moet worden voltooid voordat de app de API kan aanroepen?
    - A. Delegated permission; de functie moet inloggen als serviceaccount en de gebruiker moet toestemming geven

- B. Application permission; een beheerder moet admin consent verlenen voor de `Calendars.Read` application permission
- C. Delegated permission; admin consent wordt automatisch verleend voor achtergrondservices
- D. Application permission; de functie kan de API onmiddellijk aanroepen nadat de app registration is aangemaakt

▶ Antwoord

6. Een bedrijf implementeert 10 identieke Azure VM's die allemaal secrets moeten lezen uit dezelfde Azure Key Vault. Het securityteam wil één identiteit die onafhankelijk van individuele VM's kan worden beheerd, zodat als een VM opnieuw wordt opgebouwd, de toegang tot Key Vault niet wordt onderbroken. Welk type managed identity moet worden gebruikt?
   - A. System-assigned managed identity op elke VM
   - B. User-assigned managed identity gedeeld over alle 10 VM's
   - C. Een service principal met een gedeeld client secret over alle 10 VM's
   - D. Een system-assigned managed identity op de Key Vault-resource

▶ Antwoord

7. Een organisatie wil een on-premises intranetportal beschikbaar stellen aan externe medewerkers zonder inkomende firewallpoorten te openen. Externe gebruikers moeten authenticeren met hun Entra ID-inloggegevens en Conditional Access moet worden toegepast voordat ze de portal kunnen bereiken. Welke oplossing moet de beheerder configureren?
   - A. Site-to-site VPN tussen Azure en het on-premises netwerk
   - B. Entra Application Proxy met een connector geïnstalleerd op een on-premises server
   - C. Global Secure Access Private Access met een ZTNA-connector
   - D. Azure AD B2C voor externe authenticatie bij de intranetportal

▶ Antwoord

Week 6 — Identity governance: Entitlement en Access Reviews

> **Examendomein:** Identity governance plannen en automatiseren · **Gewicht:** 20–25%

> **Praktijkscenario:** Een zorgorganisatie met 3.000 medewerkers moet identity governance professionaliseren onder strikte NEN 7510- en ISO 27001-eisen. Artsen, verpleegkundigen en stafmedewerkers hebben verschillende access packages nodig die automatisch verlopen als een project eindigt. De complianceafdeling wil kwartaalreviews voor alle bevoorrechte rollen en HR wil uitdiensttreding binnen 24 uur terugzien in toegangsintrekking. Jij ontwerpt access packages, access reviews, lifecycle-automatisering en PIM-governance met goedkeuringsflow.

Leerdoelen

- ☐ Een Access Package aanmaken met resources, goedkeuringsworkflow en vervaldatum
- ☐ Het verschil tussen Entitlement Management en Access Reviews uitleggen
- ☐ PIM Just-in-Time access configureren voor een Entra-rol met goedkeuringsworkflow
- ☐ Eligible en Active assignments onderscheiden en het effect op de dagelijkse werkpraktijk beschrijven
- ☐ Een Access Review instellen met auto-apply resultaten en herhalingsschema
- ☐ Separation of duties configureren via incompatibele access packages
- ☐ Lifecycle Workflows uitleggen voor geautomatiseerde joiner/mover/leaver-processen

MS Learn modules

- Plan and implement entitlement management
- Plan, implement, and manage access reviews
- Implement Privileged Identity Management

Kernbegrippen

Begrip	Uitleg
Entitlement Management	Governance-framework voor het gestructureerd verlenen van toegang: catalogi, access packages, aanvraagworkflows, vervaldatums
Catalog	Container in Entitlement Management die resources groepeert (Entra-groepen, apps, SharePoint-sites) voor gebruik in access packages
Access Package	Een bundel van resources die samen als eenheid kan worden aangevraagd, goedgekeurd en ingetrokken via een vastgestelde workflow
Access Review	Periodieke controle of huidige toegangstoewijzingen nog gerechtvaardigd zijn; resultaten kunnen automatisch worden toegepast
PIM (Privileged Identity Management)	Just-in-Time activering van hoog-privilege rollen; gebruikers activeren een rol wanneer nodig met tijdslimiet en rechtvaardiging
Eligible assignment	Gebruiker heeft recht op de rol maar moet hem actief activeren via PIM (met reden, evt. MFA en goedkeuring)
Active assignment	Rol is permanent actief voor de gebruiker zonder activering — gebruikt voor break-glass en service accounts
Lifecycle Workflow	Geautomatiseerde identiteitsprocesflow voor joiner (onboarding), mover (rolwijziging) en leaver (offboarding) scenarios
Separation of duties	Beleid in Entitlement Management dat voorkomt dat een gebruiker toegang heeft tot incompatibele access packages tegelijkertijd
Break-glass account	Noodtoegangsaccount met permanente Global Administrator-rol, uitgesloten van alle CA-policies en PIM, voor gebruik bij noodgevallen

Lab oefeningen (SSW-Lab)

VM	Taak
LAB-MGMT01	Maak een *Access package* aan via **Entra** → **Identity Governance** → **Entitlement management**
LAB-MGMT01	Configureer *policy*: gebruikers kunnen zelf toegang aanvragen, manager moet goedkeuren
LAB-W11-01	Vraag het Access package aan als TestUser01 via *My Access* portal (`myaccess.microsoft.com`)
LAB-MGMT01	Keur de aanvraag goed → verifieer toewijzing
LAB-MGMT01	Maak een *Access review* aan voor een groep → wijs reviewer aan
LAB-MGMT01	Activeer **Privileged Identity Management (PIM)** voor de rol *Global Administrator*
LAB-MGMT01	Activeer de GA-rol *Just-in-time* via PIM → verifieer audit trail

Labcommando's

```
# Toon alle PIM-eligible roltoewijzingen
Get-MgRoleManagementDirectoryRoleEligibilitySchedule |
    Select-Object PrincipalId, RoleDefinitionId, Status

# Haal de PIM-activatiegeschiedenis op (audit)
Get-MgRoleManagementDirectoryRoleAssignmentScheduleRequest |
    Select-Object PrincipalId, Action, Status, CreatedDateTime, Justification

# Toon alle access packages in een catalogus
Get-MgEntitlementManagementAccessPackage |
    Select-Object DisplayName, Id, CreatedDateTime

# Haal openstaande access package-toewijzingsaanvragen op
Get-MgEntitlementManagementAssignmentRequest -Filter "state eq 'pendingApproval'"
|
    Select-Object Id, RequestType, State
```

Kennischeck

1. Wat is het verschil tussen *entitlement management* en *access reviews*?
2. Hoe werkt PIM *Just-in-Time access* en waarom is het beter dan permanente roltowijzing?

3. Wat zijn *lifecycle workflows* in Identity Governance?
4. Hoe configureer je *separation of duties* via incompatible access packages?

▶ Antwoorden

Scenario-vragen:

5. Het complianceteam van een bedrijf vereist dat de Global Administrator-rol nooit permanent aan een gebruiker wordt toegewezen. Alle beheerders moeten de rol maximaal 4 uur per keer activeren, een zakelijke rechtvaardiging opgeven en hun verzoek laten goedkeuren door het securityteam. Welke PIM-configuratie implementeert dit?
   - A. Alle beheerders een Active assignment geven met een sessietimeout van 4 uur in Conditional Access
   - B. Alle beheerders een Eligible assignment geven met een maximale activatieduur van 4 uur, goedkeuring vereisen en het securityteam configureren als goedkeurders
   - C. Alle beheerders een Active assignment geven met een vervaldatum 90 dagen vanaf nu
   - D. Een Access Package aanmaken voor de Global Administrator-rol met een vervaldatum van 4 uur

▶ Antwoord

6. Een kwartaalse access review is geconfigureerd voor de beveiligingsgroep "Finance Approvers" met auto-apply resultaten ingeschakeld. Een reviewer reageert niet op een reviewitem binnen de reviewperiode. Wat gebeurt er met de toegang van die gebruiker wanneer de review wordt afgesloten?
   - A. De toegang van de gebruiker blijft behouden omdat een reviewer toegang expliciet moet verwijderen voordat het effect heeft
   - B. De toegang van de gebruiker wordt automatisch verwijderd omdat auto-apply is ingeschakeld en het standaardgedrag bij geen respons is om toegang te verwijderen
   - C. Het reviewitem wordt geëscaleerd naar de manager van de reviewer voor een secundaire beslissing
   - D. De access review wordt met 7 extra dagen verlengd zodat de reviewer alsnog kan reageren

▶ Antwoord

7. Een organisatie wil de deactivering van gebruikersaccounts automatiseren binnen 24 uur na de laatste werkdag van een medewerker, zoals vastgelegd in het HR-systeem (via het `employeeLeaveDateTime`-attribuut in Entra ID). Welke functie moet de Identity Administrator configureren?
   - A. Een access review die handmatig door de HR-afdeling wordt gestart elke keer dat een medewerker vertrekt
   - B. Een Conditional Access policy die inloggen blokkeert na de vertrekdatum
   - C. Een Lifecycle workflow met een Leaver-trigger op basis van het `employeeLeaveDateTime`-attribuut, geconfigureerd om het account te deactiveren en groepslidmaatschappen te verwijderen

- D. Een Entra Connect Sync-regel die het AD-account verwijdert wanneer het HR-attribuut is ingesteld

▶ Antwoord

Week 7 — Examenvoorbereiding

Examendekking en verplichte labs

Doel: de huidige labs expliciet laten aansluiten op alle exam-doelstellingen.

Nog expliciet af te dekken

1. Global Secure Access verdieping: clientdeployment, Private Access en Internet Access voor Microsoft 365.
2. Cross-tenant synchronization naast standaard B2B collaboration.
3. Defender for Cloud Apps in workload identity context.
4. Identity monitoring via Log Analytics, KQL, workbooks en Identity Secure Score.

> **Noot over Global Secure Access (toegevoegd november 2025):** GSA is een volledig nieuw examenonderwerp dat per november 2025 is opgenomen in het SC-300-examen. De SSW-Lab-scripts dekken de GSA-clientinstallatie en Private Access-configuratie nog niet volledig. Besteed extra aandacht aan de MS Learn module voor Global Secure Access als aanvulling op de lab-oefeningen in week 4. Zorg dat je de drie verkeersprofielen, Universal Conditional Access en de rol van de GSA-client kunt uitleggen en configureren.

Verplichte labs voor slaagkans

1. Voer een end-to-end Global Secure Access test uit met policy, client en logging-resultaat.
2. Configureer cross-tenant synchronization met een testtenant en valideer lifecycle gedrag.
3. Maak een app registration met delegated en application permissions en leg consent impact vast.
4. Bouw 2 KQL queries voor identity logs en presenteer de interpretatie.
5. Oefen 3 PIM-rondes: eligible assignment, activation, audit en break-glass controle.

Exit criteria voordat je examen plant

1. Je kunt elk SC-300 domein verbinden aan een eigen praktijkvoorbeeld.
2. Je hebt CA, Identity Protection, workload identity en governance daadwerkelijk live getest.
3. Je kunt risico-incidenten inhoudelijk analyseren met logdata in plaats van alleen portal-clicks.

Activiteiten

- Herhaal zwakke domeinen op basis van het officiële examenstudiegids

- Doe de **Microsoft Learn oefenassessment** SC-300: Practice assessment
- Herhaal PIM-configuratie, CA What-If scenario's en entitlement management
- Maak een overzicht van alle Identity Protection risicotypes en remediation-stappen
- Plan je examen via Pearson VUE

Aandachtspunten voor het examen

- **Domeingewichten gewijzigd:** gebruikersidentiteiten 20–25%, workload-identiteiten 20–25%, governance 20–25%
- **Global Secure Access** is een nieuw examenonderwerp — ken Private Access, Internet Access en M365-profielen
- Azure RBAC voor resources („Implement access management for Azure resources") is **verwijderd** uit SC-300
- Conditional Access: *What If* scenario's, authentication strength, continuous access evaluation en protected actions
- PIM: weet het verschil tussen eligible, active en permanent assignments
- Identity governance: entitlement management vs. access reviews vs. lifecycle workflows
- B2B: cross-tenant access settings, cross-tenant synchronization en external collaboration instellingen
- App registrations: ken het verschil delegated vs. application API permissions; managed identities (system vs. user-assigned)
- Identity monitoring: KQL-query's in Log Analytics, Identity Secure Score